

Let's defend alert n.316

SOC338 – Lumma Stealer – DLL Side-Loading via Click Fix Phishing

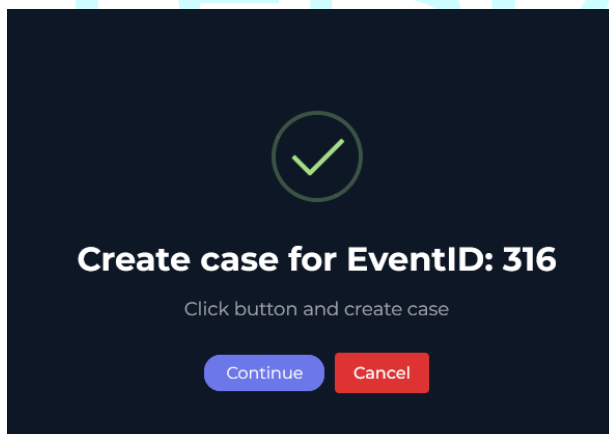
Hello, my name is Francesco, and this is my write up for the case with eventide 316. I hope the document is well written and clear for everyone. Please, if anything is wrong or not well clear to someone, contact me.

Introduction and case creation

Today we are going to complete this task from the Let's Defend platform.

Critical	Mar, 13, 2025, 09:44 AM	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing
EventID :	316	
Event Time :	Mar, 13, 2025, 09:44 AM	
Rule :	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing	
Level :	Security Analyst	
SMTP Address :	132.232.40.201	
Source Address :	update@windows-update.site	
Destination Address :	dylan@letsdefend.io	
E-mail Subject :	Upgrade your system to Windows 11 Pro for FREE	
Device Action :	Allowed	
Trigger Reason :	Redirected site contains a click fix type script for Lumma Stealer distribution.	

First, we must create the case, so we can start investigating.



Gathering information

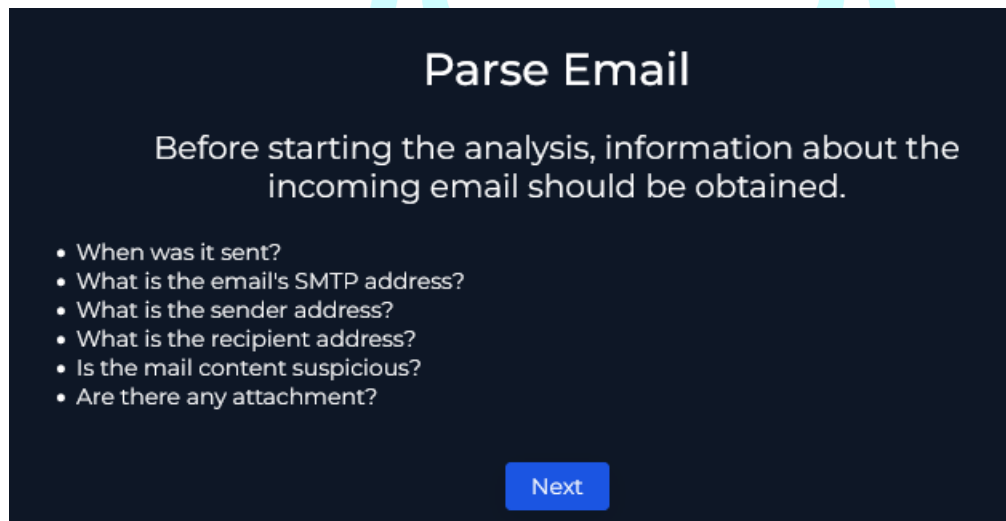
From the investigation channel, we can gather all the information we need to complete this case.

- Date: Mar 13, 2025, 09:44 AM
- SMTP Address: 132.232.40.201
- Source address: update@windows-update.site
- Destination address: dylan@letsdefend.io
- E-mail subject: Upgrade your system to Windows 11 Pro for FREE
- Trigger reason: Redirected site contains a click fix type script for Lumma Stealer distribution.

Start

(TIP: Open different tabs for easier development of the activity.)

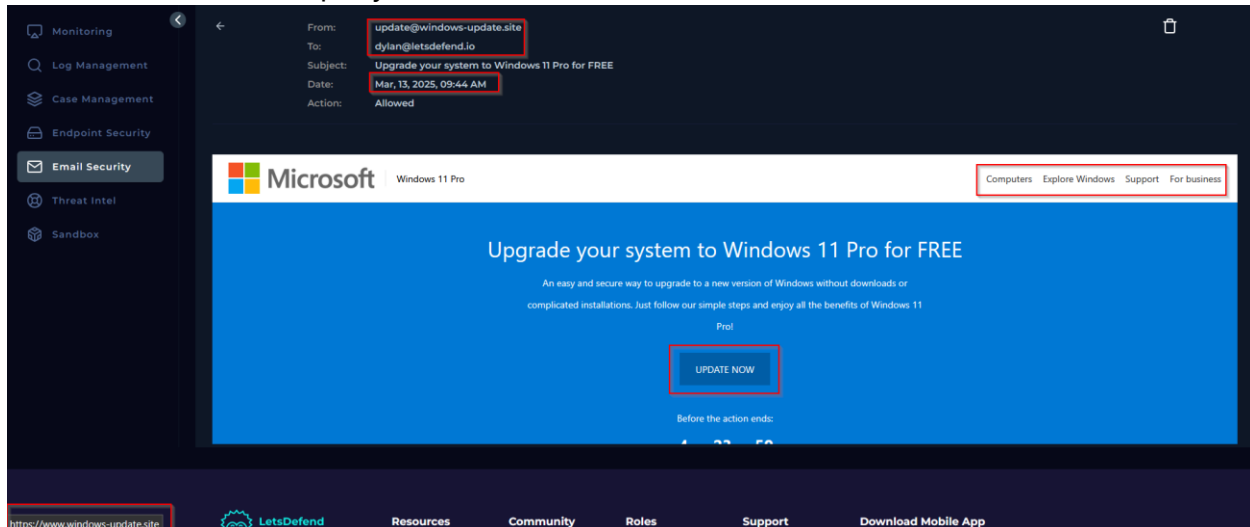
From the Investigation Channel, we create the case and start the playbook.



Before we can start completing the playbook, the platform tells us to gather all this information before. We already have most of those information, but is still important to double check them all.

Threat Intelligence

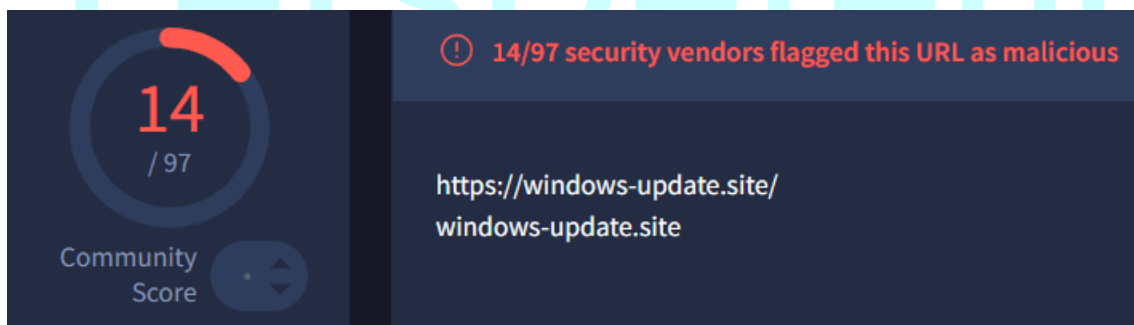
First of all, we navigate to the "Email security" tab to control the whole email received by the worker of the company.



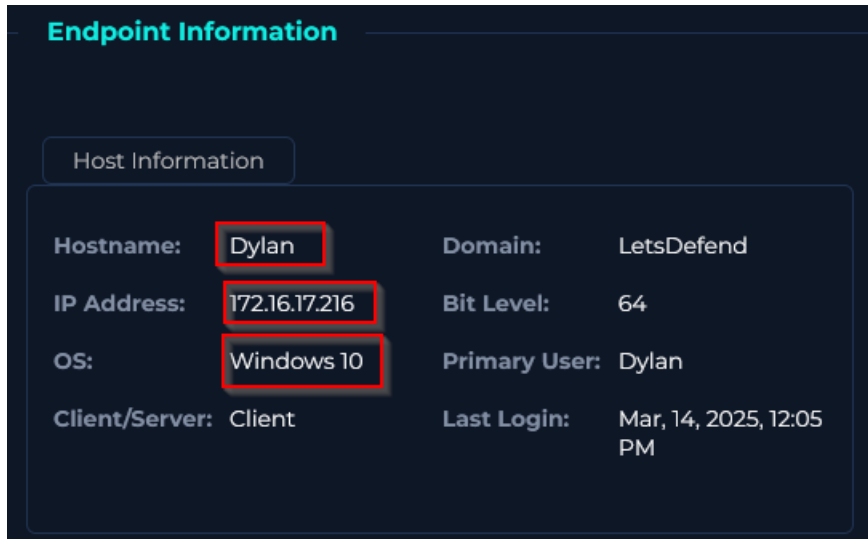
Taking a look at the email received by Dylan, we can see that every button that is about downloading and installing Windows 11 redirect to a website called "<https://windows-update.site>" meanwhile, every other buttons like "Computer", "Support" etc, does nothing, they don't have any programmed link. This is suspicious. Let's keep investigating.

Also we can affirm that there is no attachment to the email received.

Using VirusTotal, we see that the website URL is flagged as malicious by different vendors.



Let's go to the "Endpoint Security" tab and search for the Dylan's machine. We came up with this one:

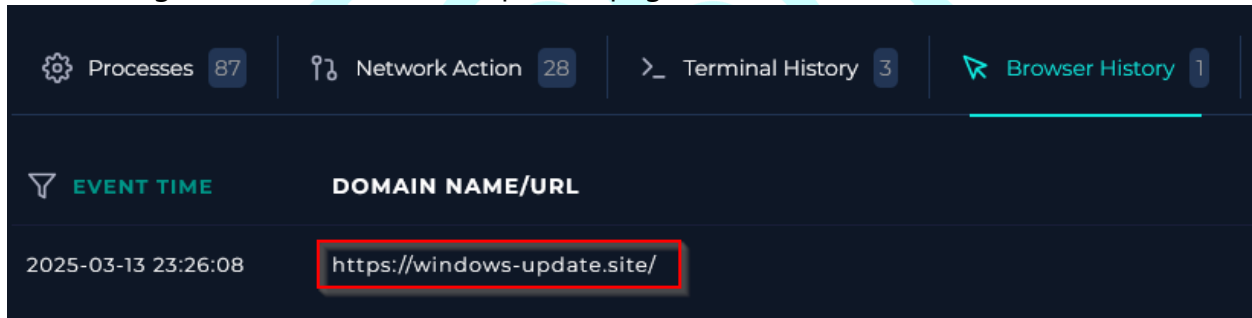


The screenshot shows the "Endpoint Information" section with a "Host Information" tab selected. The host details are as follows:

Field	Value	Field	Value
Hostname:	Dylan	Domain:	LetsDefend
IP Address:	172.16.17.216	Bit Level:	64
OS:	Windows 10	Primary User:	Dylan
Client/Server:	Client	Last Login:	Mar, 14, 2025, 12:05 PM

Let's see if this PC has been in contact with that suspicious website.

By going on the "Browser History" we see that Dylan clicked on the link present in that email and got redirected to the suspicious page



The screenshot shows the "Browser History" tab selected in the top navigation bar. Below the navigation bar, there is a table with the following data:

EVENT TIME	DOMAIN NAME/URL
2025-03-13 23:26:08	https://windows-update.site/

Now we must search for the IP where that webpage is located. For that, we go to the "Log Management" tab and search for the victim IP.

By using the filters, we can see that there is a log to a IP that has not been blocked by the firewall:

Source Address contains "172.16.17.216" and Destination Port contains "443"

✓ 14 events (before Mar, 13, 2025, 11:26 PM UTC)

< Hide Fields

INTERESTING FIELDS

type

source_address

source_port

destination_address

destination_port

raw_log

Event

source_port 27672

destination_address 132.232.40.201

destination_port 443

time Mar, 13, 2025, 11:26 PM

Raw Log

URL https://windows-update.site/

User-Agent Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:122.0) Gecko/20100101 Firefox/122.0

Referrer https://mail.letsdefend.io/

HTTP Status 200 OK

Process Name chrome.exe

With this we understand that the malicious IP is 132.232.40.201.

Let's check this IP in the "Threat Intel" tab.

We got our website IP confirmed to be that one.

Select Filters...

Free text search

Date range

Search by data type

Search by data

Search by tag

Search

Select Date

IP

132.232.40.201

Search

Search

Minimize ^

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Mar, 13, 2025, 04:58 PM	IP	132.232.40.201	Lumma, Lumma Stealer	Anonymous

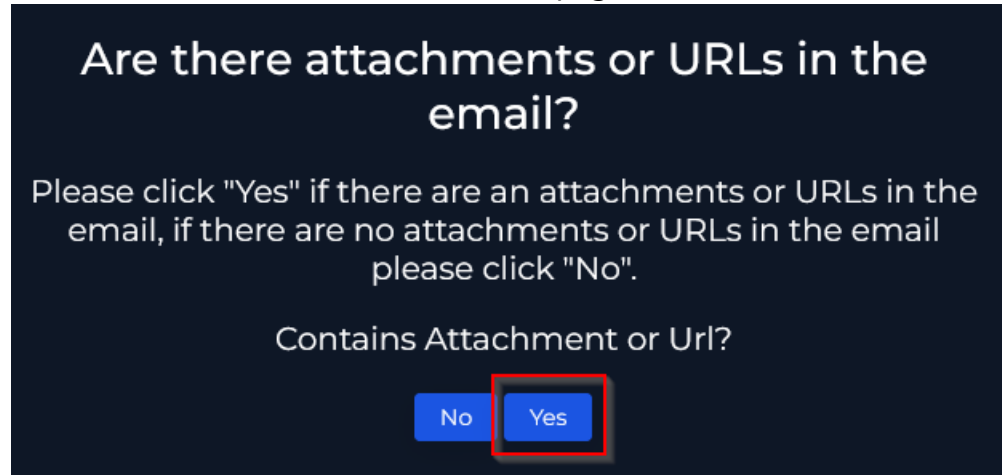
The fact that Dylan has connected to the malicious IP is also confirmed by his PC Web Connection History:

Mar 13 2025 23:26:08	132.232.40.201
----------------------	----------------

Playbook

After gathering all those information, we can start we the playbook.

We confirmed that there was no attachment to the email, BUT we saw that there were different redirections to the same Webpage on the email.



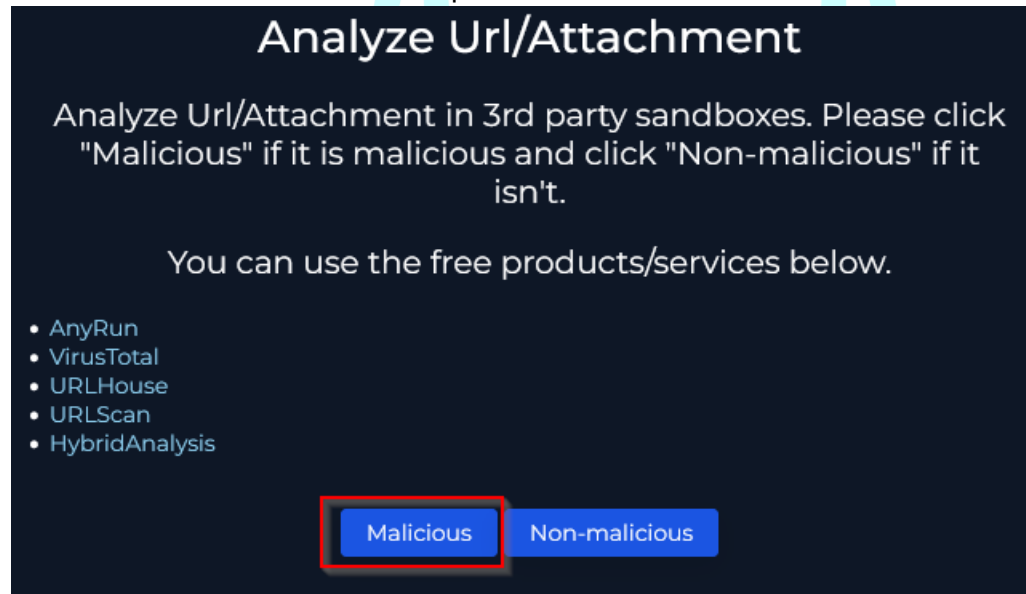
Are there attachments or URLs in the email?

Please click "Yes" if there are an attachments or URLs in the email, if there are no attachments or URLs in the email please click "No".

Contains Attachment or Url?

No Yes

By controlling the URL, we found out that the website is flagged as malicious, so we will answer affirmative to the next question:



Analyze Url/Attachment

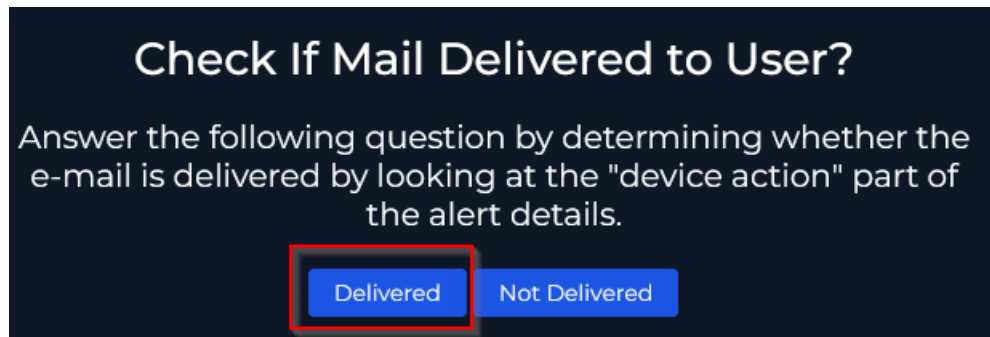
Analyze Url/Attachment in 3rd party sandboxes. Please click "Malicious" if it is malicious and click "Non-malicious" if it isn't.

You can use the free products/services below.

- AnyRun
- VirusTotal
- URLHouse
- URLScan
- HybridAnalysis

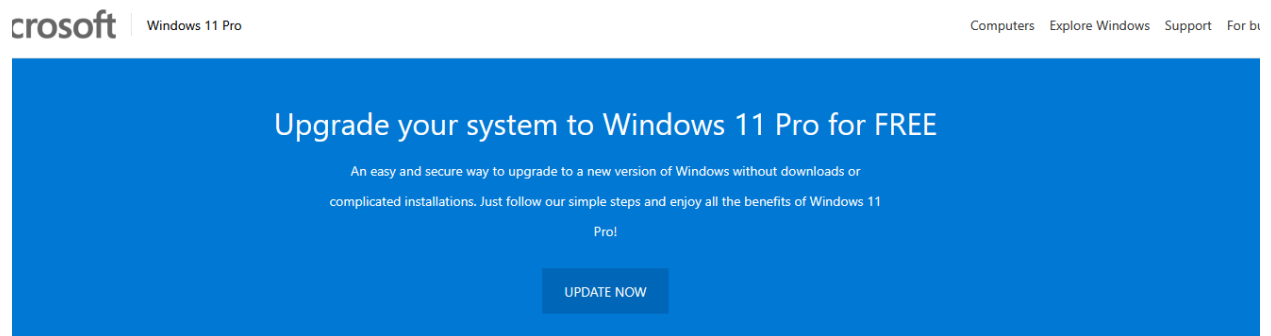
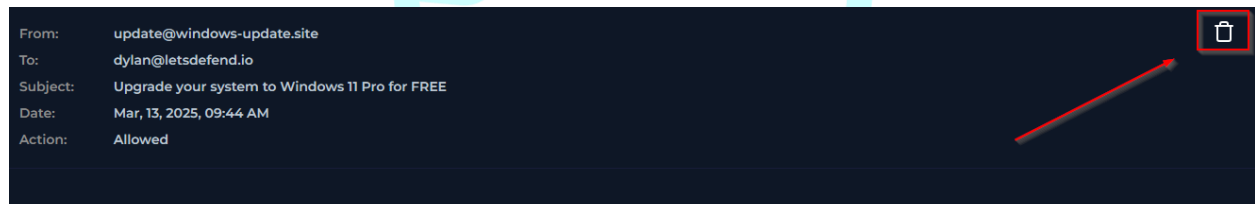
Malicious Non-malicious

The email was received by the user and opened by him. Let's answer the next question too.



Now, our job is to delete the email from the "Email Security" tab.

(WARNING: Once you delete the email, it will not be available to you even after you close the alert, so delete it once you already finished analyzing it completely.)



We already confirmed that the user opened the suspicious link, so our answer is also affirmative in this question.

Check If Someone Opened the Malicious File/URL?

Please go to the "Log Management" page and check if the c2 address accessed. You can check if the malicious file is run by searching the c2 addresses of the malicious file.

Please click "Opened" if someone access the malicious address. Otherwise please click "Not Opened" button.

The last thing to do is to contain the machine in case has been downloaded and/or opened any malicious file.

Endpoint Information

Host Information

Hostname:	Dylan	Domain:	LetsDefend
IP Address:	172.16.17.216	Bit Level:	64
OS:	Windows 10	Primary User:	Dylan
Client/Server:	Client	Last Login:	Mar, 14, 2025, 12:05 PM

Action

Containment: ☐

Endpoint Information

Host Information

Hostname:	Dylan	Domain:	LetsDefend
IP Address:	172.16.17.216	Bit Level:	64
OS:	Windows 10	Primary User:	Dylan
Client/Server:	Client	Last Login:	Mar, 14, 2025, 12:05 PM

Action

Containment: ☒ Host Contained

Now let's insert all the information we gathered through the investigation section as artifacts and, for good practice, make sure to create a good and accurate summary of the incident by answering all the 5W.

Add Artifacts

Value	Comment	Type	Remove
windows-update.site	Source email address	E-mail Se ▾	
dylan@letsdefend.io	onation email address	Select typ ▾	
windows-update[.]site	. attached in the email	URL Addr ▾	
172.16.17.216	Victim IP address	IP Address ▾	
132.232.40.201	IRL attached source IP	IP Address ▾	

LetsDefend

Conclusion

In the end, we understand that this case has been a truly positive one. We complete the case by adding some information like the URL, the source IP and the destination IP, we write a little explanation about the case, and we can close the investigation.

That was the last step. With that, we successfully completed the exercise and earned the maximum points. Congratulations!!

Critical Apr, 07, 2025, 02:09 AM SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing

EventID :	316
Event Time :	Mar, 13, 2025, 09:44 AM
Rule :	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing
Answer :	True Positive (+5 Point)
Playbook Answers :	Check If Someone Opened the Malicious File/URL? (+5 Point) Check If Mail Delivered to User? (+5 Point) Analyze Url/Attachment (+5 Point) Are there attachments or URLs in the email? (+5 Point)
Analyst Note :	During the day Mar 13, 2025, 09:44 AM Dylan received a spam email, the email was containing a suspicious URL that the worker clicked on it, it has been isolated and this alert is needed to be escalated. The IP of the suspicious Webpage is 132.232.40.201.
Rate this case :	☆
Writeups :	✍
Discussion :	💬
Share :	👤 📧 📧 📧

LetsDefend